GRYORK FINTECH PLATFORM

INTERNAL TECHNICAL DIAGNOSTIC REPORT

LSP COMPLIANCE TRANSFORMATION PROGRAMME

Classification: INTERNAL — RESTRICTED
Prepared by: Office of the CTO
Version: 1.0 — Initial Diagnostic Release
Regulatory Framework: RBI Digital Lending Guidelines | Factoring Regulation Act 2011
Audience: CTO | Lead Engineers | Product | DevOps | Compliance

This document constitutes a CTO-grade internal diagnostic for Gryork's transformation into a fully compliant Loan Service Provider (LSP). It is not a marketing or high-level strategy document. Every section contains implementable technical direction grounded in RBI Digital Lending Guidelines. Distribution is restricted to authorised personnel only.

SECTION 1 — EXECUTIVE TECHNICAL DIAGNOSTIC

1. Executive Technical Diagnostic

1.1 Where Gryork Currently Stands

Gryork has been built, as most early-stage fintech platforms are, with a primary focus on functional utility rather than regulatory architecture. The platform successfully orchestrates a complex operational chain: it onboards borrowers, facilitates KYC collection, validates invoices, coordinates EPC confirmations, matches borrowers with NBFCs, and monitors disbursements and repayments. From a product perspective, this is a meaningful and sophisticated workflow. From a regulatory architecture perspective, however, it is a startup-grade system operating inside what must become a regulated fintech infrastructure.

The distinction matters profoundly. A startup-grade system optimises for speed of delivery, feature completeness, and user experience. A regulated fintech system, by contrast, must additionally optimise for audit integrity, consent enforceability, data sovereignty, role-based access control at a granular level, and NBFC-grade trust infrastructure. These are not minor additions. They represent a fundamental architectural shift in how the platform is designed, how data flows, how decisions are recorded, and how third-party NBFCs can rely on the platform's outputs without assuming operational risk themselves.

As of this diagnostic, Gryork does not have a Compliance Enforcement Engine. It does not have a tamper-proof, independently accessible Document Repository. Its audit trail is functional but not legally enforceable as-is. It lacks a structured Consent Management System aligned with DPDPA principles. It has no formal KFS (Key Fact Statement) generation and cooling-off enforcement module. Its escrow monitoring is observational rather than automated. Its NBFC access layer is either absent or entirely mediated through Gryork's own interface, which creates a dangerous platform dependency problem. These are not minor product gaps — they are regulatory exposure points that could prevent any serious NBFC from onboarding or, worse, create post-disbursement compliance liability.

1.2 Why Gryork Is Not NBFC-Ready Yet

The RBI's Digital Lending Guidelines (DLG), introduced in September 2022 and operationalised through circular RBI/2022-23/111, impose specific and non-negotiable obligations on Loan Service Providers. These are not aspirational guidelines — they are enforceable mandates. An NBFC that partners with an LSP that fails to meet these standards is itself exposed to regulatory risk, which is why serious NBFCs now conduct exhaustive technology and compliance due diligence on any LSP they engage.

The core problem is not that Gryork cannot perform the right functions — it clearly can. The problem is that the platform cannot prove to a regulatory auditor, or to an NBFC's compliance team, that those functions were performed correctly, with proper consent, in the right sequence, with the right controls, and

with an independently verifiable record. The regulatory standard is not 'did you do the right thing' — it is 'can you prove, without reliance on your own system's testimony, that the right thing was done correctly.'

NBFCs will ask for: independent document access without going through Gryork's interface; cryptographically verifiable audit logs of every workflow step; system-enforced KFS delivery before disbursement; system-enforced cooling-off periods; evidence that fee deductions were not processed by Gryork on behalf of the NBFC; and evidence that all data sharing with third parties was preceded by explicit, time-stamped, purpose-specific borrower consent. None of these requirements are currently met at the architectural level.

1.3 Key Risks Identified from Diagnostic

1.3.1 Platform Dependency Risk

Currently, all data, documents, workflows, and access are mediated through Gryork's own platform. If Gryork's systems experience downtime, a data incident, a legal dispute, or simply a technical failure at a critical moment, the NBFC has no independent means of accessing borrower documents, confirming workflow completion, or continuing its credit operations. This is unacceptable from an NBFC risk management perspective. The RBI expects NBFCs to maintain independent records of all loan decisions, not to rely on third-party LSP platforms for access to critical documentation. This single dependency risk alone is sufficient grounds for an NBFC to decline or terminate an LSP relationship.

1.3.2 Lack of Independent Document Access

Borrower documents — KYC files, invoices, EPC confirmations, sanction letters, loan agreements — must be accessible by the NBFC independently of Gryork's operational status. Currently, there is no independent document repository designed for this purpose. Documents likely reside in Gryork's own storage infrastructure, accessible only through Gryork's authenticated interfaces. The NBFC has no direct-access mechanism, no API key with its own credentials to pull documents, and no guarantee of document integrity beyond Gryork's own assertions. An NBFC compliance audit will immediately flag this as a critical gap.

1.3.3 Weak Audit Trail

An audit trail is only legally useful if it is immutable, timestamped by a trusted third-party timestamp authority, and complete in its recording of every action taken by every actor in the system. What Gryork likely has today is a functional log — records of what happened, stored in a database that Gryork itself controls. This is useful for operational debugging. It is not useful for legal or regulatory proceedings because the logs can theoretically be altered, and there is no independent cryptographic proof of the chain of custody of each action. In a lending context, audit trails are the mechanism by which a borrower can challenge a process, an NBFC can defend a credit decision, and a regulator can reconstruct the full sequence of events. Weak audit trails are a systemic legal vulnerability.

1.3.4 Missing Compliance Infrastructure

There is no DLG Enforcement Engine — a system module that acts as a compliance gate, preventing the workflow from proceeding if required regulatory steps have not been completed. There is no module that generates and delivers a standardised KFS to the borrower before disbursement. There is no system-level enforcement of the three-day cooling-off period, nor a module that verifies that disbursement

flows directly from the NBFC's account to the borrower's account without passing through Gryork. These are not optional features — they are system controls that the RBI requires. If they are manual processes or human-dependent checks, they are insufficient. They must be automated, logged, and verifiable.

SECTION 2 — LSP TECH ARCHITECTURE REQUIREMENTS

2. LSP Technology Architecture Requirements

2.1 What an LSP System Must Have

The RBI's framework for Loan Service Providers is explicit: an LSP facilitates lending but does not bear credit risk, does not hold client funds, and does not make lending decisions. However, this does not mean the LSP's technical obligations are light. Quite the opposite — the LSP is the primary interface between borrowers and regulated lenders, which makes the LSP's system the primary site of regulatory exposure in the entire lending chain.

An LSP system must have, at minimum: a consent management system that captures purpose-specific, time-stamped, revocable borrower consent before any data is shared with an NBFC or any third party; a KFS generation module that produces standardised Key Fact Statements containing all material loan terms before any disbursement is authorised; a cooling-off enforcement engine that system-prevents disbursement for a minimum of three days after KFS delivery; an independent document repository that NBFCs can access directly with their own credentials; a tamper-proof audit trail that records every action with cryptographic integrity; and a DLG compliance gate that verifies all mandatory regulatory steps before allowing any workflow to advance to the next stage.

Beyond these mandatory elements, the LSP system must also provide: GST validation for invoice authenticity; CKYC and Aadhaar-based identity verification; bank account verification for both borrowers and EPCs; Account Aggregator integration for financial data consent; credit bureau pulling for borrower scoring; CERSAI integration for security interest search; e-signature and digital signature infrastructure for legally valid document execution; escrow monitoring with NBFC-visible reconciliation; and a fraud detection engine. Each of these is not a feature enhancement — they are the infrastructure requirements for a system that NBFCs will trust with their regulatory compliance chain.

2.2 Separation of LSP, NBFC, and Borrower

The most important architectural principle for an LSP system is strict role separation. The borrower, the NBFC, and the LSP must each have their own data context, their own access layer, and their own interaction surface. Data that belongs to the borrower must not be visible to the NBFC unless explicit, purpose-specific consent has been obtained and logged. Actions taken by Gryork as LSP must not be attributable to the NBFC and vice versa. The NBFC must be able to act within the platform — accessing documents, reviewing applications, issuing sanctions — without being dependent on Gryork's interface to do so.

At the system level, this means: three separate authentication domains, each with their own credential infrastructure; three separate data stores with no shared tables or schemas; API-level access controls that enforce role permissions at every endpoint; an event-driven architecture where each actor's actions

produce independently logged, timestamped records; and a clear data flow design that ensures consent is verified before any cross-boundary data transfer occurs. The NBFC Dashboard must be a genuinely independent interface — not a view within the Gryork admin panel, but a separately accessible, separately authenticated system that the NBFC can access through its own credentials, including when Gryork's own staff are not available.

2.3 System-Level Compliance Expectations

Compliance in a regulated fintech context is not a feature — it is the operating system. Every module in the platform must be designed with compliance as a first principle, not as a layer added after the functional module is built. This means that the workflow engine itself must enforce compliance gates: a loan application cannot move from KYC to credit assessment without the system verifying that Aadhaar consent was obtained through the Aadhaar Authentication User Agency framework. A disbursement instruction cannot be issued without the system verifying that the KFS was delivered, that the cooling-off period has elapsed, and that the borrower has not exercised their right to exit. These are not manual checks — they are hard system stops coded into the workflow state machine.

The expectation from NBFC technology evaluators is that when they onboard onto Gryork's platform, they can be confident that the LSP's system architecture itself protects them from inadvertent regulatory non-compliance. This is a significantly higher bar than what most startups build to. It requires the development team to think not in terms of 'what does this feature do' but 'what does this feature prevent from going wrong.'

SECTION 3 — CURRENT GAP ANALYSIS (CRITICAL)

3. Current Gap Analysis

The following gaps have been identified through a CTO-level diagnostic review of Gryork's current architecture. Each gap is presented with its associated risk, impact on NBFC readiness, and the required architectural fix. These are not enhancements — they are non-negotiable requirements for regulatory compliance.

A. Compliance Layer Missing

GAP A — No Compliance Enforcement Engine	
Risk	Without a system-level compliance gate, regulatory obligations under DLG are enforced only through human processes. This creates inconsistency, auditability failure, and regulatory exposure for both Gryork and its NBFC partners. If a single loan is disbursed without KFS delivery, or before the cooling-off period elapses, Gryork becomes the proximate cause of an RBI compliance violation.
Impact	No NBFC with a mature compliance function will onboard onto an LSP platform that relies on manual compliance checks. The impact is direct: NBFC partnership deals will stall at due diligence. Beyond commercial impact, if the RBI audits the NBFC and finds non-compliance attributable to the LSP's process, both entities face enforcement action. The NBFC faces the regulatory action; Gryork faces loss of the partnership and potential prohibition from LSP activities.
Required Fix	Build a Compliance Enforcement Engine (CEE) as a standalone service within GRYLINK Core Engine. The CEE must function as the sole gatekeeper for workflow state transitions. It must check: consent status before data sharing, KFS delivery timestamp before disbursement, cooling-off period expiry before disbursement, and disbursement routing verification. All checks must be automated, logged, and produce cryptographically signed compliance certificates for each loan.

B. Audit Trail Weak

GAP B — Non-Immutable Audit Log	
Risk	The current audit trail is stored in a database that Gryork controls and can modify. In any legal or regulatory dispute, Gryork cannot present this audit trail as independent evidence because any opposing party can argue that the records may have been altered. An audit trail that is not cryptographically immutable is legally worthless in adversarial proceedings.
Impact	If a borrower disputes a fee, if an NBFC challenges a document's authenticity, or if the RBI conducts a supervisory review, the lack of an immutable audit trail means Gryork has

	no reliable evidence of what actually happened and when. This could expose Gryork to civil liability, regulatory censure, and permanent loss of NBFC trust.
Required Fix	Implement a hash-chain audit log system where every recorded event is cryptographically linked to the previous event. Every log entry must include: a SHA-256 hash of the event data, a reference to the previous entry's hash, a Trusted Timestamp Authority (TSA) timestamp under RFC 3161, and a digital signature from Gryork's system certificate. This makes the audit trail tamper-evident — any modification to any past record breaks the hash chain. Store audit logs in an append-only data store (e.g., immutable S3 with Object Lock, or a dedicated blockchain-anchoring service).

C. No Independent Document Repository

GAP C — No NBFC-Accessible Document Store	
Risk	All documents are stored within Gryork's own infrastructure and are accessible only through Gryork's interfaces. The NBFC has no independent path to retrieve borrower documents, loan files, or KYC records. If Gryork experiences technical downtime, a data incident, or a legal freeze, the NBFC loses access to all documentation related to its own loan portfolio — documents that are legally the NBFC's records.
Impact	This is a fundamental trust failure from an NBFC's perspective. The NBFC is legally required to maintain borrower records for up to eight years under RBI guidelines. If those records are housed in Gryork's systems and Gryork becomes unavailable, the NBFC is in regulatory violation through no fault of its own. No risk-aware NBFC will accept this structural dependency. This gap alone can kill NBFC partnerships at the due diligence stage.
Required Fix	Design and build an Independent Document Repository (IDR) as a separately hosted, separately authenticated storage system. The IDR must: accept document pushes from Gryork's workflow engine at each stage; apply TSA timestamps to every document upon upload; generate cryptographic fingerprints (SHA-256) for each document; provide the NBFC with direct API access using its own credentials, completely independent of Gryork's operational status; and guarantee document delivery within 30 minutes of NBFC request. The IDR must be hosted on infrastructure with 99.99% uptime SLA, separate from Gryork's main application servers.

D. No Consent Architecture

GAP D — Absent Consent Management System	
Risk	Gryork currently collects borrower data and shares it with NBFCs without a purpose-specific, time-stamped, documented consent framework. Under the Digital Personal Data Protection Act (DPDPA) concepts and RBI DLG requirements, every instance of data sharing with a third party must be preceded by explicit, informed, revocable consent for that specific purpose. The absence of this architecture means every data transfer Gryork has made to an NBFC may be technically unconsented.
Impact	The regulatory risk is severe. Under the DPDPA framework, unconsented data sharing exposes the data fiduciary to significant penalties. Under RBI DLG, the LSP is required to ensure that borrower data shared with the RE (Regulated Entity) is covered by

	documented consent. If the RBI finds that Gryork has been sharing borrower data with NBFCs without a compliant consent framework, enforcement action is likely. Additionally, any borrower who challenges a data sharing instance will find that Gryork cannot produce a consent record — which is an indefensible position.
Required Fix	Build a Consent Management System (CMS) as a standalone module. The CMS must: present purpose-specific consent requests to the borrower at every relevant workflow stage (onboarding, data sharing with NBFC, credit bureau pull, Account Aggregator access, etc.); capture consent with timestamp, IP address, device fingerprint, and purpose code; store consent records in the immutable audit log; allow borrowers to view and revoke their consents from within the borrower interface; and function as a gate that the Compliance Enforcement Engine checks before any data transfer proceeds.

E. No DLG Enforcement Engine

GAP E — Manual or Absent DLG Workflow Controls	
Risk	The RBI's Digital Lending Guidelines specify several mandatory process controls: KFS must be delivered before disbursement, the cooling-off period must be honoured, disbursement must flow directly from NBFC to borrower, and fees charged by the LSP must not be deducted from the loan amount at source. None of these controls currently exist as system-enforced gates in Gryork's workflow.
Impact	Each of these controls exists to protect the borrower from predatory practices. If Gryork cannot demonstrate that these controls are system-enforced and not merely process-advisory, it fails the RBI's LSP compliance standard. A single failure — one disbursement that did not follow the direct-route requirement, one loan where the cooling-off was waived — creates regulatory liability for the NBFC partner and potentially triggers supervisory action against both entities.
Required Fix	Embed DLG compliance controls directly into the workflow state machine. This means: the system must be technically incapable of issuing a disbursement instruction unless the KFS delivery event is recorded in the audit trail and the cooling-off period has elapsed. These must be hard system stops, not soft warnings. The disbursement module must validate the destination account against the borrower's verified bank account (not any account designated by the LSP). Fee deduction mechanisms must be architecturally separated from disbursement flows. Every DLG check must produce a signed compliance certificate appended to the loan record.

F. Weak Escrow Monitoring

GAP F — Observational Rather Than Automated Escrow Tracking	
Risk	The current escrow monitoring capability appears to be observational — Gryork can see what is happening in escrow accounts but cannot enforce rules, trigger alerts, or produce automated reconciliation reports. Disbursement and repayment flows pass through financial infrastructure that the NBFC needs to trust, but the monitoring layer does not provide the NBFC with real-time visibility or independent reconciliation.
Impact	Escrow integrity is central to the trust relationship between the LSP and the NBFC. If funds move through an escrow mechanism and the NBFC cannot independently verify

	the routing, amounts, and timing, it cannot fulfil its own regulatory obligation to track disbursement and repayment flows. Any discrepancy — even an accidental one — becomes a liability dispute in which the NBFC has no independent evidence of what occurred in the escrow.
Required Fix	Integrate with NPCI or licensed banking APIs to build a real-time Escrow Monitoring Engine. This engine must: track every credit and debit event in the escrow account with UTC timestamps; reconcile expected disbursements against actual fund movements; automatically alert the NBFC if a fund movement does not match an authorised disbursement instruction; produce daily reconciliation reports that both Gryork and the NBFC can independently access; and flag any unmatched or late repayment events to the NBFC dashboard in real time.

G. No NBFC Access Layer

GAP G — NBFC Access Mediated Through Gryork Interface	
Risk	The NBFC currently interacts with the platform through interfaces that Gryork controls. There is no independently accessible NBFC dashboard, no NBFC-specific API credentials, and no mechanism for the NBFC to access its own portfolio data independently. This creates a structural platform dependency that makes Gryork not just a service provider to the NBFC but a mandatory operational intermediary.
Impact	If Gryork's platform is unavailable, the NBFC has no visibility into its own loan portfolio. If Gryork's staff are unavailable, the NBFC cannot complete operational tasks. This is incompatible with the NBFC's own operational continuity requirements and its RBI obligations. NBFCs must be able to operate their core lending functions regardless of the operational status of any third-party LSP.
Required Fix	Design and deploy a fully independent NBFC Access Layer — a separately hosted, separately authenticated interface and API set through which the NBFC can: access all documents in the IDR using its own credentials; view its full loan portfolio including status, disbursement amounts, and repayment schedules; generate compliance reports; review and sign off on credit decisions without requiring Gryork staff involvement; and receive real-time webhook notifications for all portfolio events. This layer must remain functional even if Gryork's main application experiences an outage.

H. API Integrations Missing or Unclear

GAP H — Incomplete API Integration Architecture	
Risk	Multiple critical API integrations required for LSP operations — Account Aggregator, CERSAI, TSA for document timestamping, bank account verification, and a fraud detection rule engine — are either absent or not integrated at an architectural level that produces auditable, regulatory-grade outputs. API integrations that exist may be point solutions without proper error handling, fallback logic, or audit logging.
Impact	Missing API integrations create operational gaps where critical data cannot be verified, compliance cannot be enforced, or documents cannot be stamped with regulatory-grade provenance. An Account Aggregator integration gap, for example, means the LSP cannot facilitate compliant financial data sharing — which is now expected by serious NBFCs as

	part of their credit assessment process. A missing TSA integration means all documents in the system lack independent timestamp proof.
Required Fix	Conduct a complete API integration audit and map every required external API to the specific module it serves, the data it produces, and the workflow stage at which it is triggered. Build integrations with proper authentication management (certificate rotation, API key vaulting), structured error handling with graceful degradation, full request and response logging in the audit trail, and test suites that verify integration behaviour under failure conditions. All API integrations must produce outputs that are stored in the IDR and referenced in the audit trail.

SECTION 4 — SYSTEM ARCHITECTURE (TARGET STATE)

4. Target State System Architecture

4.1 Architecture Overview

The target architecture for Gryork as a compliant LSP is a multi-tier, role-segregated platform composed of five primary interface layers and one central orchestration engine. Each interface layer serves a distinct actor with distinct permissions. The central engine — GRYLINK Core Engine — acts as the brain of the system, orchestrating all workflow logic, enforcing compliance gates, and producing the audit trail. All external API integrations are managed through a dedicated API Gateway layer that handles authentication, rate limiting, and audit logging for every external call.

The five primary interface layers are: the Borrower Application (mobile and web), which is the sole interface through which borrowers submit information, sign documents, and manage their consent profile; the EPC Interface, through which Engineering Procurement Contractor entities confirm invoices and provide project-level validations; the NBFC Dashboard, which is a fully independent interface through which NBFCs access their portfolio, review applications, and access documents; the Admin Panel, which is Gryork's internal operational interface for its own staff; and the GRYLINK Core Engine, which is the backend orchestration layer that no external actor accesses directly.

4.2 GRYLINK Core Engine

The GRYLINK Core Engine is the most critical architectural component. It must be designed as a microservices-based system where each compliance function is an independently deployable, independently scalable service. The Core Engine contains: the Workflow Orchestrator, which manages the state machine for each loan application through its lifecycle; the Compliance Enforcement Engine, which acts as the gate between every workflow state transition; the Consent Management Service, which validates consent status before any data operation; the Audit Service, which records every event from every actor in the immutable, hash-chained log; the Document Management Service, which coordinates document uploads, fingerprinting, timestamping, and delivery to the IDR; and the Notification Service, which delivers regulatory-grade notifications (KFS, cooling-off notices, consent requests) to borrowers through verifiable channels.

4.3 Data Flow and Control Points

The data flow in the target architecture follows a strict consent-first, compliance-gate-enforced path. When a borrower initiates an application, the Consent Management Service first captures and records explicit consent for each data collection and sharing purpose. No data is collected without a corresponding consent record. The KYC module collects identity data and triggers CKYC, PAN, and

Aadhaar verification APIs. Verified KYC data is stored in the borrower's encrypted data partition and is not accessible to the NBFC until a credit assessment consent has been captured.

When the application progresses to credit assessment, the Compliance Engine verifies consent status, then triggers the Account Aggregator integration and credit bureau pull. Results are stored in the borrower's partition and simultaneously pushed to the IDR with TSA timestamps. When the NBFC makes a credit decision, it does so through its own dashboard with its own credentials — Gryork's systems record the decision but do not make it. When the NBFC issues a sanction, the KFS Generation Module creates the Key Fact Statement, delivers it to the borrower through a verifiable channel, and records the delivery timestamp. The Compliance Engine then starts the cooling-off countdown. Only after the cooling-off period has elapsed, and only after the borrower has not exercised their right of exit, does the system permit the NBFC to initiate disbursement. Disbursement instructions flow from the NBFC's own banking infrastructure directly to the borrower's verified account. Gryork's Escrow Monitoring Engine observes and records but does not intermediate the fund flow.

SECTION 5 — CORE MODULES (DETAILED)

5. Core Modules — Detailed Specification

5.1 KYC & Identity Module

The KYC & Identity Module is the first gate in the borrower journey. Its function is to establish a verified, immutable identity record for every borrower entity — whether an individual, a partnership, or a company. In the infrastructure receivable financing context, borrowers are typically business entities, which means the KYC scope must cover both the entity itself (MCA21 verification, GST registration, PAN-to-entity linkage) and its authorised representatives (individual Aadhaar, PAN, CKYC records).

Architecturally, the KYC module must be built as a stateless verification service that calls external APIs — CKYC registry, UIDAI Aadhaar Authentication, NSDL PAN verification, and MCA21 — and produces a structured, cryptographically signed KYC result record. This record is stored in the borrower's encrypted partition and pushed to the IDR. The KYC module must support both Video KYC (for higher-value applications) and OTP-based Aadhaar authentication. Critically, all Aadhaar data handling must comply with the UIDAI's Aadhaar Authentication User Agency framework — Gryork cannot store raw Aadhaar numbers; it must store only masked numbers and the authentication token.

The KYC module is why this system is a regulated fintech platform and not a startup app: every design decision must be made with the understanding that the KYC record it produces is the foundation of the NBFC's credit file. Errors, gaps, or non-compliant data handling in the KYC module create downstream regulatory problems for the NBFC's own portfolio.

5.2 GST Validation Engine

The GST Validation Engine is specific to Gryork's infrastructure receivable financing model and is not a standard LSP module — but it is critical given the nature of the assets being financed. Infrastructure invoices are the collateral underlying the lending transaction. If those invoices are fraudulent, duplicated, or based on disputed GST filings, the NBFC's credit decision is made on a false premise.

The GST Validation Engine must call the GSTN API to verify: the GST registration status of the invoicing entity, the filing status of the relevant return periods (GSTR-1, GSTR-3B), the specific invoice data as reflected in the GSTN system, and the cross-match between the invoice amount claimed and the amount reflected in the GST filing. The engine must produce a validation result that includes the API response, the timestamp, and a machine-readable status code. This validation record must be stored in the IDR as part of the credit file.

A key architectural requirement is that the GST Validation Engine must be capable of detecting duplicate invoice submissions — the same invoice being submitted for financing to multiple NBFCs through potentially different LSPs. While Gryork cannot query other LSPs' systems, it must at minimum validate

that the same invoice has not been submitted through Gryork's own platform more than once, and flag any invoice where the GSTN data shows the receivable has already been settled.

5.3 EPC Confirmation Engine

The EPC Confirmation Engine manages the multi-party confirmation workflow unique to infrastructure receivable financing. An EPC contract involves the Engineering Procurement Contractor as the party responsible for confirming the work completion that justifies the invoice being financed. This confirmation is a critical credit event — it is the EPC's acknowledgement that the receivable is genuine, undisputed, and eligible for financing.

The EPC Confirmation Engine must manage: a secure, authenticated EPC interface through which EPC representatives can access the specific invoices requiring confirmation; a notification workflow that alerts the EPC to pending confirmations; a digital signature mechanism through which the EPC's confirmation is executed as a legally valid, timestamped electronic signature; and an escalation mechanism for invoices that do not receive confirmation within a defined timeframe. Every EPC confirmation must be stored in the IDR with its digital signature and TSA timestamp, making it a legally enforceable document in any dispute about the validity of the underlying receivable.

5.4 Document Validation Engine

The Document Validation Engine uses OCR, ML-based document classification, and rules-based validation to verify the authenticity and completeness of every document submitted by the borrower. In the infrastructure financing context, this includes invoices, purchase orders, work completion certificates, bank statements, and project agreements.

The engine must be capable of: extracting structured data from unstructured documents using OCR; cross-referencing extracted data against known data points (e.g., verifying that the GSTIN on an invoice matches the entity's registered GSTIN, that the invoice date falls within a valid window, that the invoiced amount matches GSTN data); flagging documents that appear altered or inconsistent; and producing a validation report that is stored in the IDR. The Document Validation Engine must be integrated with a fraud detection module that applies rule-based and ML-based anomaly detection to identify forged or manipulated documents.

5.5 Loan Processing Engine

The Loan Processing Engine is the workflow orchestrator that manages the lifecycle of every loan application from submission to disbursement. It is not a credit decisioning engine — Gryork as an LSP does not make credit decisions. It is a process management engine that ensures every required step is completed, documented, and verified before the application advances to the next stage.

The Loan Processing Engine must be implemented as a finite state machine where every state transition is: triggered by a specific event (KYC verified, GST validated, EPC confirmation received); validated by the Compliance Enforcement Engine; recorded in the immutable audit trail; and notified to all relevant parties (borrower, NBFC, Gryork admin). The engine must support parallel state management for

applications at different stages and must handle exception states (KYC rejection, document fraud flag, EPC non-confirmation) with defined workflow paths that are logged and auditable.

5.6 KFS + Cooling-Off Engine

The KFS + Cooling-Off Engine is one of the most important compliance modules in the entire system. The Key Fact Statement requirement under RBI DLG mandates that before any loan disbursement, the borrower must receive a standardised document — in the prescribed RBI format — containing the loan amount, interest rate expressed as an Annual Percentage Rate (APR), all fees and charges, repayment schedule, consequences of default, and the grievance redressal mechanism.

The engine must: generate the KFS in the exact format prescribed by the RBI, populated with data from the specific loan offer; deliver the KFS to the borrower through a channel that produces delivery proof (email with read receipt, SMS with delivery confirmation, in-app notification with acknowledgement event); record the exact timestamp of delivery in the audit trail; and start a cooling-off period counter from the moment of confirmed delivery. The cooling-off period — a minimum of three days as mandated by RBI DLG — must be enforced as a hard system stop. The Loan Processing Engine must be architecturally incapable of processing a disbursement instruction unless the CEE confirms that the cooling-off period has elapsed and no exit request has been received.

During the cooling-off period, the system must also provide the borrower with a clear, easily accessible mechanism to exit the loan without any penalty. This exit mechanism must be logged, and any exit event must immediately halt the disbursement workflow and notify the NBFC.

5.7 Escrow Monitoring Engine

The Escrow Monitoring Engine provides real-time visibility into fund flows through any escrow or intermediary account used in the disbursement and repayment process. Its primary function is not to control fund flows — Gryork does not handle funds — but to provide an independent, automated record of every fund movement that can be reconciled against expected disbursement instructions and repayment schedules.

The engine must integrate with banking APIs or payment system webhooks to receive real-time notifications of credit and debit events. Each event must be matched against a pending expected transaction record, and the match result logged in the audit trail. Unmatched transactions — credits or debits that do not correspond to any authorised instruction — must trigger immediate alerts to the NBFC dashboard and the Gryork admin panel. Daily reconciliation reports must be generated automatically and stored in the IDR, accessible to the NBFC through its independent dashboard.

5.8 Audit Trail Engine

The Audit Trail Engine is the system of record for everything that happens on the platform. It is not a logging module — it is a compliance infrastructure component that produces legally defensible records of every action taken by every actor. Every event in the system — every API call, every document upload, every consent captured, every workflow state transition, every NBFC access event, every admin action — must produce an audit record in this engine.

The architecture must implement a hash-chain design: each audit record contains a SHA-256 hash of its own data and a reference to the hash of the immediately preceding record. This produces a chain where any alteration to any past record is immediately detectable because it breaks the hash chain. Additionally, the engine must periodically submit batch hashes to a TSA (RFC 3161 compliant) to produce external timestamp anchors that prove the log existed in its current state at a specific point in time. This combination of hash-chaining and external timestamping produces an audit trail that is tamper-evident and that can be used in legal proceedings.

5.9 Consent Management System

The Consent Management System manages the full lifecycle of borrower consent — capture, storage, validation, and revocation. It operates on a purpose-specific model: a single consent for 'data collection' is insufficient. Every distinct purpose — KYC data sharing with NBFC, credit bureau pull, Account Aggregator data access, marketing communications — requires a separate, explicitly captured consent record.

The CMS must present consent requests to the borrower in plain language, in the borrower's preferred language where possible, with a clear description of the specific purpose, the data to be shared, and the recipient entity. The borrower's consent action — acceptance or rejection — must be captured with timestamp, device fingerprint, and session identifier. The CMS must expose a borrower-facing consent dashboard where all active consents are visible and any consent can be revoked. Revocation must be instantaneous — the moment a consent is revoked, the CEE must prevent any further data sharing under that consent purpose.

5.10 NBFC Access Dashboard

The NBFC Access Dashboard is an independently hosted, separately authenticated web application through which NBFC users manage their loan portfolio on the Gryork platform. It is not a view within Gryork's admin panel. It is a distinct application with its own authentication infrastructure, its own API credentials, and its own hosting environment.

The dashboard must provide: a portfolio overview showing all applications in each workflow stage; direct access to documents in the IDR using NBFC-specific credentials; the ability to issue credit decisions and sanction letters; real-time escrow monitoring and reconciliation data; compliance reporting tools; and a notification centre for all portfolio events. The NBFC must be able to perform all core operational functions through this dashboard without any involvement from Gryork's staff.

5.11 Independent Document Repository

The Independent Document Repository is the crown jewel of the compliance infrastructure. It is a document storage system designed from the ground up for regulatory compliance and NBFC trust. Every document that passes through the Gryork platform — KYC files, invoices, EPC confirmations, sanction letters, loan agreements, KFS documents, consent records — must be stored in the IDR with a cryptographic fingerprint, a TSA timestamp, and metadata that records the context of the document (who submitted it, when, in what workflow stage, under what consent).

The IDR must be hosted on separate infrastructure from Gryork's main application, with its own disaster recovery and business continuity plan. It must provide NBFC direct access through the NBFC's own API credentials, with no dependency on Gryork's operational status. Document delivery SLA must be 30 minutes or less from NBFC request. The system must support retention for the regulatory minimum of eight years, with automated lifecycle management. All documents must be stored in encrypted form (AES-256 at rest) and transmitted only over encrypted channels (TLS 1.2 minimum, TLS 1.3 preferred).

SECTION 6 — API INTEGRATION LAYER

6. API Integration Layer

The API Integration Layer is the connective tissue between Gryork's internal modules and the external data, verification, and financial infrastructure services upon which the platform's compliance capabilities depend. Every integration must be treated as a compliance-critical system component — not as a third-party feature add-on. API failures must produce auditable fallback states, not silent failures. Every API call must be logged in the Audit Trail Engine with request parameters (sanitised of PII where required), response status, and timestamp.

API	Module	Data Fetched	Trigger Point
GST / GSTN API	GST Validation Engine	GST registration status, return filing history, invoice-level data, cross-match with submitted invoices	On invoice submission by borrower; re-validated before credit committee review
CKYC Registry	KYC & Identity Module	Central KYC records for individual and entity; existing KYC flag; KYC identifier	At start of borrower onboarding; refreshed if 12 months elapsed since last KYC
UIDAI Aadhaar Auth	KYC & Identity Module	Identity verification via OTP or biometric; masked Aadhaar number; auth token	For individual KYC verification; mandatory for loan agreements above threshold value
NSDL PAN Verify	KYC & Identity Module	PAN validity, name-to-PAN linkage, PAN-Aadhaar link status	At onboarding; before credit assessment; before loan agreement execution
Account Aggregator	KYC & Identity + Credit	Bank statements, GST-linked financial data, investment data — all consent-gated via AA framework	After credit assessment consent captured; pulled to support underwriting by NBFC
CIBIL / Equifax / CRIF	Loan Processing Engine	Credit score, credit history, existing loan obligations, delinquency records	After KYC is verified and credit bureau consent is captured; pre-sanction stage
MCA21 API	KYC & Identity Module	Company registration status, director details, charges filed, annual filing compliance, beneficial ownership	At entity onboarding; refreshed before disbursement to check for interim charge registration
CERSAI API	Document Validation Engine + Loan Processing	Existing security interest search against asset; registration of new security interest post-sanction	Search triggered before credit decision; registration triggered after loan agreement execution

E-Sign / DSC / eStamp	KFS Engine + Loan Processing	Legally valid electronic signatures on loan agreements, KFS acknowledgements, consent documents	For KFS execution, loan agreement signing, consent captures requiring attestation
TSA (RFC 3161)	Audit Trail Engine + IDR	Trusted third-party timestamp tokens for all audit events and documents	On every document upload to IDR; on every audit log batch anchor; on KFS delivery
Bank Account Verify	KYC & Identity Module	Account existence, account holder name match, IFSC validity, account status	At onboarding for borrower bank registration; mandatory before disbursement routing
Escrow / NPCI APIs	Escrow Monitoring Engine	Real-time debit and credit events, fund movement timestamps, transaction references	Continuously post-disbursement; on every repayment due date; for reconciliation
OCR / Document AI	Document Validation Engine	Extracted text and structured data from invoices, certificates, bank statements, identity documents	On every document upload; before document is accepted into the credit file
Fraud Detection Engine	Document Validation + Loan Processing	Fraud risk score, anomaly flags, known fraud pattern matches, duplicate submission detection	On KYC submission, document upload, and any data inconsistency flag from other modules

6.1 API Integration Architectural Standards

Every API integration must conform to the following engineering standards without exception. Authentication credentials for all external APIs must be stored in a secrets management vault (e.g., HashiCorp Vault or AWS Secrets Manager) — never in application code or environment files checked into version control. Certificate-based authentication must be used wherever the API provider supports it; shared secret rotation must be automated on a schedule not exceeding 90 days.

Every API call must be wrapped in a circuit breaker pattern to handle provider outages gracefully. When an API is unavailable, the system must: log the failure event with full context; enter a defined fallback state (e.g., manual review queue for document validation); prevent the workflow from silently proceeding as if the API had succeeded; and alert the operations team through the monitoring system. The principle is that a failed API call must produce a known, auditable state — not a silent gap in the compliance record.

API responses that contain PII must be processed in-memory and stored only in the encrypted borrower data partition. Raw API responses must never be stored in unencrypted logs or general application databases. Every API integration must have a corresponding test suite covering: successful response handling, error response handling, timeout handling, malformed response handling, and partial data scenarios.

SECTION 7 — DLG COMPLIANCE ENFORCEMENT ENGINE

7. DLG Compliance Enforcement Engine

7.1 Architectural Philosophy

The DLG Compliance Enforcement Engine (CEE) embodies a fundamental design principle: compliance must be architectural, not operational. In most regulated systems, compliance is treated as a process — human reviewers check that steps were followed, checklists are signed off, and supervisors approve. This approach is inadequate for an LSP operating at scale because human-dependent compliance checks are inconsistent, undocumentable in real time, and unenforceable at speed. The CEE replaces human-dependent compliance checks with system-enforced compliance gates that are technically impossible to bypass.

The CEE is not a module that checks whether compliance has occurred — it is the mechanism through which the system makes non-compliant workflow progression technically impossible. This is the difference between an advisory system and an enforcement system. Every NBFC partner and every RBI examiner will expect the latter.

7.2 Direct Disbursement Enforcement

RBI DLG mandates that loan disbursements must flow directly from the Regulated Entity (NBFC) to the borrower's bank account. The LSP must not intermediate fund flows. The CEE enforces this by: verifying, at the point of disbursement instruction, that the destination account matches the borrower's verified bank account recorded in the KYC module; confirming that the disbursement instruction originates from the NBFC's banking infrastructure and not from any Gryork-controlled account; recording the disbursement routing details in the audit trail; and flagging any disbursement instruction that does not match the verified routing for immediate review.

The CEE must maintain a verified account registry — a record of confirmed NBFC and borrower bank accounts that have passed the bank verification API check. Disbursement instructions that reference accounts outside this registry must be blocked and escalated. This is a hard system stop, not a soft warning.

7.3 KFS Delivery Before Disbursement

The CEE enforces KFS delivery as an absolute pre-condition for disbursement. The gate check works as follows: when the NBFC issues a disbursement instruction through its dashboard, the CEE intercepts the instruction and queries the KFS Event Log. If the KFS Event Log does not contain a confirmed delivery record — a record with a TSA-stamped timestamp and a delivery confirmation from the channel provider

— the disbursement instruction is rejected. If the delivery record exists but has been created within the minimum cooling-off window, the instruction is queued with a system-calculated release time.

The CEE also verifies that the KFS delivered to the borrower matches the terms of the disbursement instruction. If the sanction terms have changed since the KFS was delivered, a new KFS must be generated, delivered, and confirmed before disbursement can proceed. The CEE must detect any parameter change between the KFS-generation event and the disbursement instruction and apply this verification automatically.

7.4 Cooling-Off Period Enforcement

The three-day cooling-off period is the borrower's right to exit the loan agreement after receiving the KFS. The CEE enforces this by maintaining a cooling-off state for each loan application. From the moment the KFS delivery is confirmed, the system sets a cooling-off expiry timestamp at exactly 72 hours (or more, if a specific NBFC or product category requires it). The workflow engine is architecturally blocked from processing any disbursement instruction while the cooling-off flag is active.

During the cooling-off period, the borrower must have an accessible, friction-free mechanism to signal their desire to exit the loan. This mechanism — a button in the borrower app, a response to the KFS delivery notification — must produce an immediate cancellation event in the Loan Processing Engine. The NBFC must be notified of the exit through its dashboard in real time. Exit events must be logged with full context in the audit trail. The CEE must prevent any attempt by any actor — including Gryork admin users — to shorten or override the cooling-off period.

7.5 Fee Separation Enforcement

The RBI's position on LSP fees is clear: fees charged by the LSP for its services must not be deducted from the loan disbursement amount. The borrower must receive the full sanctioned loan amount. LSP fees must be separately collected. The CEE enforces this by verifying that the disbursement instruction amount matches the sanctioned loan amount in the credit file, with no deductions applied. If the disbursement instruction reflects any deduction, the CEE blocks the instruction and flags it for compliance review.

Gryork's fee collection mechanism must be completely architecturally separate from the disbursement flow. If Gryork's fees are to be collected from the NBFC (which is the compliant model — the NBFC pays the LSP, not the borrower), this must occur through a separate invoicing and settlement mechanism that is clearly documented in the NBFC partnership agreement and in the audit trail.

7.6 Consent Verification Before Data Sharing

The CEE's consent gate is the final line of defence before any borrower data is shared with any external party, including the NBFC. Before any data transfer event — credit bureau pull, Account Aggregator data sharing, document delivery to NBFC — the CEE queries the Consent Management System to verify: that an active, unrevoked consent record exists for the specific purpose, that the consent was captured from the borrower (not on the borrower's behalf), that the consent has not expired, and that the recipient of the

data matches the entity named in the consent record. Any data sharing operation that does not pass all four checks must be blocked and logged.

SECTION 8 — DOCUMENT STORAGE & PLATFORM FAILURE SOLUTION

8. Document Storage & Platform Failure Solution

8.1 The Platform Failure Problem

Platform failure is not a hypothetical scenario in the context of LSP-NBFC relationships — it is a scenario that every NBFC's risk team will explicitly assess before entering a partnership. Platform failure encompasses technical outages, data incidents, regulatory freezes, insolvency proceedings, and litigation-driven access injunctions. In any of these scenarios, the NBFC needs to be able to access its own portfolio documentation independently of the LSP's operational status. If it cannot, it has surrendered operational control of its own loan book to a third-party LSP — which is an unacceptable risk position for any regulated lending institution.

The Independent Document Repository solves this problem by ensuring that documents are not merely stored in Gryork's systems but are simultaneously stored in an independently accessible, separately hosted repository where the NBFC has direct, credential-based access that does not pass through any Gryork application server or authentication system.

8.2 IDR Architecture Design

The IDR must be built on a cloud-native object storage system (AWS S3 with Object Lock, or equivalent) configured for WORM (Write Once Read Many) storage. WORM configuration ensures that once a document is written to the IDR, it cannot be deleted or modified by any actor, including Gryork's own administrators. Documents can only be appended; existing records are immutable.

The IDR service layer — the API through which documents are uploaded, retrieved, and searched — must be hosted on infrastructure that is logically and physically separate from Gryork's main application stack. It must have its own domain, its own TLS certificates, its own authentication infrastructure (a separate identity provider), and its own database for document metadata. In a failure scenario involving Gryork's main systems, the IDR service must continue to operate independently.

The NBFC's access to the IDR must be through credentials issued by the IDR's own identity system — not through Gryork's SSO or API gateway. This means the NBFC can authenticate to the IDR and retrieve documents even if Gryork's authentication systems are completely offline. The IDR's authentication system must support industry-standard protocols (OAuth 2.0, OpenID Connect) with certificate-based client authentication for machine-to-machine access.

8.3 TSA Timestamping Integration

Every document stored in the IDR must receive a TSA timestamp at the moment of storage. The timestamping process works as follows: when a document is submitted to the IDR, the system computes a SHA-256 hash of the document contents; this hash is submitted to a qualified TSA (compliant with RFC 3161 and, where relevant, the Information Technology (Electronic Signature) Rules); the TSA returns a timestamp token — a signed data structure containing the hash, the timestamp, and the TSA's digital signature; this token is stored alongside the document in the IDR. The TSA timestamp provides irrefutable proof that the document existed in its current, unmodified form at the recorded time. This is the mechanism that gives documents in the IDR their legal evidentiary weight.

8.4 30-Minute NBFC Access SLA

The 30-minute document access SLA for NBFCs is not an arbitrary service standard — it reflects the operational reality that NBFCs must be able to respond quickly to RBI examination requests, borrower queries, and internal credit review processes. The IDR must be architected to meet this SLA under all conditions, including peak load and partial system degradation.

Meeting this SLA requires: an indexed, searchable document metadata layer that allows the NBFC to find documents by loan ID, borrower ID, document type, and date range without scanning the full document store; pre-signed, time-limited access URLs that allow the NBFC to download documents directly from the storage layer without passing through an application tier; and a monitoring system that alerts Gryork's SRE team if NBFC access latency exceeds threshold.

SECTION 9 — AUDIT & LOGGING SYSTEM

9. Audit & Logging System

9.1 The Legal Enforceability Standard

An audit log is legally valuable only if it is tamper-evident, complete, timestamped by a trusted external authority, and accessible in a format that can be understood by a non-technical examiner. The logs that most application systems produce by default — rows in a database table with timestamps assigned by the application server — do not meet this standard. They are operationally useful but legally weak because they can be altered without trace, they rely on the application server's clock (which can be manipulated), and they have no external verification anchor.

Gryork's Audit Trail Engine must meet a higher standard. Every log entry must be part of a cryptographically continuous chain. The system must record not just what happened but who performed the action, from which IP address and device, in which session, at what step in which workflow, and what the state of the system was before and after the action. This granularity is what makes the audit trail usable in regulatory examinations, civil disputes, and fraud investigations.

9.2 Events That Must Be Logged

Without exception, every event in the following categories must produce an audit record: all authentication events (login, logout, failed login, MFA challenge, session token issuance and expiry) for all user types; all document events (upload, download, deletion attempt, metadata modification, IDR push, TSA timestamp receipt); all consent events (presentation, acceptance, rejection, revocation, expiry); all KYC events (initiation, API call and response, verification result, KYC record creation); all workflow state transitions (application created, KYC verified, documents validated, NBFC matched, credit decision made, KFS generated, KFS delivered, cooling-off started, cooling-off expired, disbursement authorised, disbursement confirmed); all NBFC actions (login, document access, credit decision, sanction issued, disbursement instruction, portfolio report accessed); all admin actions (user creation, permission change, configuration change, override of any workflow step); all API calls (to and from external services, including request/response status and timestamp); and all compliance gate checks (pass or fail, with the specific condition evaluated).

9.3 Immutability Architecture

The Audit Trail Engine's immutability is achieved through three mechanisms working in combination. First, the hash-chain design ensures that any modification to a past log entry is detectable by checking the hash chain forward from that entry. Second, WORM storage ensures that the physical storage layer itself prevents modification of written records. Third, periodic TSA anchoring — where the Audit Trail Engine

computes a hash of all entries since the last anchor and submits it to the TSA — provides external, time-stamped proof of the log's state at regular intervals. An examiner can verify the integrity of any section of the audit log by: recomputing the hash chain from the section of interest, verifying it against the nearest TSA anchor, and confirming the anchor with the TSA's own records.

The audit log must be retained for a minimum of eight years, consistent with RBI's record retention requirements. The storage infrastructure must support long-term archival with retrieval capability within 48 hours for any period within the retention window.

SECTION 10 — ESCROW & PAYMENT TRACKING SYSTEM

10. Escrow & Payment Tracking System

10.1 Escrow's Role in the LSP Architecture

In infrastructure receivable financing, escrow accounts serve multiple functions: they may hold disbursed funds pending specific disbursement triggers, they may collect repayments from project owners, and they may be the mechanism through which the underlying receivable's payment flows are directed. In each of these roles, the escrow account is a critical control point in the lending transaction, and the integrity of the fund flows through it is essential to both the NBFC's credit risk management and the regulatory compliance of the transaction structure.

Gryork, as the LSP, does not hold or control the escrow. But Gryork is responsible for providing the NBFC with real-time, independently verifiable visibility into escrow fund movements. This requires a real-time integration between the Escrow Monitoring Engine and the banking or payment infrastructure that manages the escrow account.

10.2 Integration Design

The Escrow Monitoring Engine must integrate with the escrow bank's API infrastructure — either directly through the bank's banking API or through an NPCI-approved payment system interface — to receive real-time webhook notifications of every credit and debit event in each monitored escrow account. The engine must maintain a registry of all escrow accounts associated with active loan transactions on the platform, with the corresponding expected transaction schedule derived from the loan disbursement and repayment terms in the credit file.

Every fund movement event received from the banking API must be immediately matched against the expected transaction registry. The matching logic must compare: the transaction amount (within an acceptable tolerance for bank charges), the value date, the counter-party account (to verify the source or destination of funds), and the transaction reference code. Successfully matched transactions must be logged in the audit trail and the corresponding loan record updated. Unmatched transactions must be flagged for investigation and escalated to both the Gryork operations team and the NBFC dashboard.

10.3 NBFC Visibility and Automated Reconciliation

The NBFC must have real-time visibility into its portfolio's escrow positions through the NBFC Access Dashboard. This visibility must include: current balances in all escrow accounts associated with its portfolio; a transaction history with matching status for each event; upcoming expected disbursements and repayments with due dates; and any flagged, unmatched, or late transactions. Daily automated

reconciliation reports must be generated by the Escrow Monitoring Engine and made available in the IDR under the NBFC's direct access, so that the NBFC can produce these reports in any audit without requesting them from Gryork.

SECTION 11 — SECURITY & DATA GOVERNANCE

11. Security & Data Governance

11.1 Role-Based Access Control

Role-Based Access Control (RBAC) must be implemented across every component of the Gryork platform with a principle of least privilege: every user, system service, and API credential must have access only to the specific data and functions required for their role, and nothing more. The RBAC model must be implemented at the data layer — not just at the application layer — so that a user with inappropriate role claims cannot bypass application-level controls by accessing the database directly.

The platform must define at minimum the following role families: Borrower roles (with access limited to the borrower's own application data and documents); EPC roles (with access limited to invoices requiring their confirmation); NBFC roles (portfolio manager, credit analyst, compliance officer — each with defined permissions); Gryork operations roles (application reviewer, KYC officer, compliance manager, system administrator); and system service roles (each microservice with specific, scoped credentials for the resources it needs). All role assignments must be logged in the audit trail. Privilege escalations must require multi-party authorisation and must produce immediate audit events.

11.2 Data Segregation

Borrower data, EPC data, and NBFC data must be stored in logically and, where possible, physically separate data partitions. Borrower PII must never reside in the same database table as NBFC operational data. The application layer must enforce this separation through the data access layer — there must be no ORM query path that returns borrower data in a context accessible to the NBFC layer without passing through the consent verification gate.

In practice, this means separate database schemas (or separate database instances for particularly sensitive data categories), separate encryption keys for each data partition, separate backup and recovery procedures, and separate access logs for each partition. A database administrator should not be able to query borrower data using the same credentials used for operational monitoring.

11.3 Encryption Standards

All data at rest must be encrypted using AES-256 with keys managed in a dedicated key management system (KMS) — not stored alongside the data. All data in transit must use TLS 1.2 at minimum, with TLS 1.3 as the preferred standard. All inter-service communication within the Gryork microservices architecture must be encrypted and mutually authenticated (mTLS). Cryptographic key rotation must be

automated and must occur on a schedule not exceeding 12 months for data-at-rest keys and 90 days for transit keys.

PII data — Aadhaar numbers, PAN numbers, bank account numbers, mobile numbers — must be encrypted not just at the storage layer but also at the field level. Field-level encryption means that even a database administrator with access to the database cannot read PII fields without the specific field-level encryption key, which is managed separately and accessed only by authorised application services.

11.4 Consent-Based Data Sharing

Every data sharing event — whether between Gryork modules, between Gryork and an external API, or between Gryork and the NBFC — must be preceded by a consent check through the Consent Management System. The data sharing architecture must be designed so that it is technically impossible for data to flow from one context to another without passing through the consent gate. This is not a policy requirement applied by developers — it is an architectural requirement enforced by the system design.

In practical terms, this means the data access layer must include a consent check as a mandatory step in every cross-context data retrieval. If the consent check fails (no valid consent, revoked consent, expired consent), the data retrieval must return an access denied response, and the attempt must be logged in the audit trail as a consent violation attempt.

SECTION 12 — CTO RESPONSIBILITY

12. CTO Responsibility Section

12.1 The CTO's Compliance Accountability

In a regulated fintech platform, the CTO's accountability extends beyond engineering delivery. The CTO is the senior technical officer responsible for ensuring that the technology system meets its regulatory obligations. If the platform fails a regulatory examination because a required system control was not built, the CTO cannot shift accountability to the product or engineering team. The CTO signed off on the architecture. The CTO is accountable for what was built and what was not.

This means the CTO must maintain active knowledge of the regulatory requirements applicable to the platform — not at the level of reading RBI circulars once and delegating implementation, but at the level of being able to articulate, in a regulatory examination, exactly how each requirement is met in the system architecture and be able to demonstrate it through the audit trail. This requires the CTO to be involved in compliance design reviews, not just technical architecture reviews.

12.2 System Readiness Before NBFC Onboarding

No NBFC should be onboarded onto the Gryork platform until the system has achieved a minimum viable compliance state. The minimum viable compliance state is defined as: the Compliance Enforcement Engine is deployed and tested; the Independent Document Repository is live and independently accessible; the KFS + Cooling-Off Engine is in production; the Consent Management System is capturing and storing purpose-specific consents; the Audit Trail Engine is producing hash-chained, TSA-anchored log records; the NBFC Access Dashboard is available and independently hosted; and all critical API integrations — KYC, GST, bank verification, and e-sign — are live and producing auditable outputs.

The CTO must personally certify, in writing, that each of these components has been tested in a staging environment that mirrors production, that test evidence is retained in the project documentation, and that the system has passed an internal compliance walkthrough conducted with the compliance team (or external compliance advisor). This certification becomes part of the NBFC onboarding documentation and may be requested by the NBFC's compliance team or by the RBI.

12.3 Audit Readiness Mindset

The most important mindset shift the CTO must instil in the engineering team is this: every feature must be designed as if an RBI examiner will review the audit trail of that feature next week. This is not a metaphor — it is a practical design constraint. The examiner will ask: what did the system do, when did it do it, who authorised it, what data was accessed, and can you prove it without relying on the system's

own testimony? If the engineering team cannot answer these questions about a feature from its audit trail, the feature is not production-ready for a regulated environment.

The CTO must establish a quarterly internal audit review process where a cross-functional team — engineering, compliance, and operations — reviews a sample of recent loan transactions and walks through the audit trail end-to-end. Any gaps, ambiguities, or missing events in the audit trail must be treated as high-priority defects and addressed before the next NBFC onboarding.

SECTION 13 — DEVELOPMENT ROADMAP

13. Development Roadmap

The roadmap is structured in three phases that progressively build towards full regulatory maturity. Phase 1 establishes the minimum compliance infrastructure without which NBFC onboarding cannot proceed. Phase 2 builds the compliance maturity that enables the platform to scale with confidence and pass rigorous NBFC due diligence. Phase 3 builds the scale infrastructure and advanced capabilities that position Gryork as a market-leading LSP.

PHASE 1 — Minimum NBFC-Ready State (Weeks 1–12)

Timeline: 12 Weeks

- Deploy Independent Document Repository with WORM storage, TSA timestamping, and NBFC direct-access credentials
- Build and deploy Consent Management System with purpose-specific consent capture, storage, and revocation
- Implement KFS Generation Engine in the prescribed RBI format with delivery confirmation and timestamp recording
- Build Cooling-Off Enforcement Module as a hard system gate in the Loan Processing Engine
- Integrate bank account verification API for all disbursement routing validation
- Deploy Audit Trail Engine with hash-chain design and first TSA anchor configuration
- Build NBFC Access Dashboard as an independently hosted application with separate authentication
- Implement DLG disbursement routing validation — block any disbursement not routed to the verified borrower account
- Integrate CKYC, PAN verification, and Aadhaar authentication APIs in the KYC module
- Deploy Compliance Enforcement Engine with KFS, cooling-off, and consent gate checks
- Complete internal compliance walkthrough and CTO certification before first NBFC onboarding

PHASE 2 — Compliance Maturity (Weeks 13–28)

Timeline: 16 Weeks

- Integrate Account Aggregator framework for consent-gated financial data sharing
- Integrate credit bureau APIs (CIBIL, Equifax, or CRIF) with full consent gate enforcement
- Build GST Validation Engine with GSTN API integration and duplicate invoice detection
- Deploy EPC Confirmation Engine with digital signature for EPC confirmation events
- Implement CERSAI integration — search before credit decision, registration after loan execution
- Build Document Validation Engine with OCR, data extraction, and cross-reference validation
- Deploy Fraud Detection Rule Engine with anomaly flagging and escalation workflows
- Implement MCA21 API integration for entity-level KYC and charge register search
- Build Escrow Monitoring Engine with real-time bank API integration and automated reconciliation

- Deploy full field-level encryption for all PII data categories
- Implement mTLS for all inter-service communication within the microservices architecture
- Establish quarterly internal audit review process
- Conduct first full NBFC compliance walkthrough with an onboarded NBFC compliance team

PHASE 3 — Scale Infrastructure (Weeks 29–52)

Timeline: 24 Weeks

- Implement Video KYC capability for high-value and non-Aadhaar OTP scenarios
- Build multi-NBFC portfolio management with full data segregation between NBFC contexts
- Deploy advanced ML-based fraud detection with continuous model retraining
- Implement automated regulatory reporting module generating RBI-format reports
- Build disaster recovery infrastructure with cross-region replication for IDR and audit trail
- Achieve and certify ISO 27001 compliance for information security management
- Deploy API rate limiting, DDoS protection, and WAF for all externally facing endpoints
- Build borrower-facing consent dashboard with full consent history and revocation capability
- Implement advanced analytics for NBFC credit committee with portfolio-level risk visualisation
- Establish Bug Bounty programme and conduct first external penetration test
- Document and certify full business continuity and disaster recovery procedures
- Prepare platform for RBI inspection readiness — compile complete compliance evidence pack

SECTION 14 — TEAM INSTRUCTION SECTION

14. Team Instructions — Regulated Fintech Development

IMPORTANT: You are not building a startup application. You are building a regulated financial infrastructure that will be examined by the Reserve Bank of India, evaluated by NBFC compliance teams, and relied upon by borrowers whose livelihoods depend on the integrity of the financing transactions it facilitates. Every line of code you write carries regulatory weight.

14.1 Backend Engineering Team

Every API endpoint must be designed with authentication, authorisation (role check), input validation, audit logging, and error response as mandatory, non-optional components — not features to be added later. There is no such thing as an 'internal-only endpoint that doesn't need authentication.' In a regulated system, all endpoints require authentication because the audit trail requires a verified actor identity for every event.

Database schema design must reflect data sovereignty principles: borrower data, NBFC data, and Gryork operational data must never share tables. Foreign key relationships that cross data sovereignty boundaries must pass through an application-layer consent gate, not be implemented as direct database joins. PII fields must be identified in the schema and encrypted at the field level using the KMS-managed keys — not at the table level, not at the disk level, but at the field level.

The workflow state machine must be the authoritative record of every loan application's status. No other component in the system must be able to modify an application's status directly. All state transitions must pass through the Workflow Orchestrator, which calls the Compliance Enforcement Engine before executing the transition. Any state transition that occurs without this path is a compliance violation, not an engineering convenience.

Error handling must be designed for compliance: when an external API fails, the system must not fail silently or proceed as if the API had succeeded. It must enter a defined, logged, auditable failure state. The error response must include enough context for the audit trail to record what was attempted, what failed, and what action was taken in response. Silent failures are unacceptable — they create gaps in the audit trail that become regulatory vulnerabilities.

14.2 Frontend / Mobile Team

The Borrower App is a regulated interface. Every screen that presents information to the borrower — particularly KFS delivery, consent requests, and loan terms — must meet the RBI's readability and disclosure standards. Consent capture screens must present the consent purpose in clear, plain-language text (not legal boilerplate). The borrower must actively accept each consent — pre-ticked boxes or implied

consent designs are not compliant. Consent rejection must be as easy as acceptance — the UX must not make rejection difficult or hide it behind multiple steps.

The NBFC Dashboard must be engineered to a higher reliability standard than the borrower app because it is used by regulated entities for regulatory compliance purposes. Every action a user takes in the NBFC Dashboard — document access, credit decision, portfolio review — must produce an audit event. The frontend must send action events to the audit trail backend, not rely solely on backend state changes to generate the audit record. This dual-source approach ensures that even if a backend state change is delayed, the audit trail records what the user intended to do.

The cooling-off countdown must be visually prominent in the borrower interface — it must not be hidden in settings or small text. The borrower's right to exit must be communicated clearly at every interaction during the cooling-off period, and the exit mechanism must be accessible from the notification delivered with the KFS.

14.3 DevOps / Infrastructure Team

The infrastructure architecture must implement a genuine separation of environments: development, staging, and production must be completely separate accounts, separate networks, and separate credentials. No developer credentials must have access to production data. Production deployments must require a multi-party authorisation gate — no single engineer can deploy to production without a second authorised approver. All deployment events must be logged in the audit trail as administrative actions.

The Independent Document Repository and the Audit Trail Engine must each have their own dedicated infrastructure — separate VPCs, separate storage accounts, separate monitoring stacks, and separate disaster recovery configurations. These components must have uptime SLAs of 99.99% — four nines — which means the infrastructure must support automated failover, cross-region replication, and regular DR drills. The hosting contract for these components must include data sovereignty clauses ensuring data residency within India.

All secrets — API keys, database credentials, TLS certificates, KMS keys — must be stored in a secrets management system with automated rotation. Environment files with credentials must never be committed to version control. Access to the secrets management system must be logged. The monitoring and alerting system must cover: application error rates, API latency, authentication failure rates, audit trail write failures, IDR storage failures, and any anomalous access patterns that may indicate a breach attempt.

14.4 Product Team

Product decisions in a regulated fintech platform are not purely commercial decisions — they are regulatory decisions. Before any new feature is added to the product roadmap, the product team must conduct a Regulatory Impact Assessment (RIA) asking: does this feature involve collecting new data types (which may require new consent categories), does it change the data sharing model with NBFCs, does it affect any workflow step that is governed by DLG, and does it require new API integrations that produce data with compliance implications.

Feature prioritisation must give absolute priority to compliance infrastructure over user experience enhancements. The minimum viable product for an LSP is not a product that is easy to use — it is a

product that is compliant to use. An easy-to-use but non-compliant product will be shut down. A compliant product that is somewhat harder to use can be improved. This is the product team's north star for the duration of the LSP transformation programme.

The product team must also own the borrower communication design for all regulatory notifications — KFS delivery, consent requests, cooling-off notices, exit rights communications. These are not just UX design tasks — they are regulatory documents. They must be reviewed by the compliance team before release, and any change to their content or design must go through the same review process as a change to a legal document.

> *Final Instruction to All Teams: When in doubt about whether a design decision is compliant, the answer is to ask the compliance team before building — not to build first and ask later. The cost of retrofitting compliance into a non-compliant system is an order of magnitude higher than building compliance in from the start. This document exists so that you have clarity from the beginning. Use it.*